

GOOGLE CYBERSECURITY CERTIFICATE

# Access Control

## Google Cybersecurity Professional Certificate · Study Guide

Two access-control incident worksheets — investigating unauthorized payroll access by a former contractor, and analyzing a data leak caused by overpermissioned sharing — both grounded in the NIST SP 800-53 least-privilege control (AC-6).

|           |                                               |
|-----------|-----------------------------------------------|
| Track     | Google Cybersecurity Professional Certificate |
| Course    | Assets, Threats, and Vulnerabilities          |
| Framework | NIST SP 800-53 (AC-6 — Least Privilege)       |
| Analyst   | Chayan Panchal                                |

## 1 Incident 1 — Unauthorized Payroll Access

An authorization/authentication review flagged an account with admin-level access reaching payroll systems well after it should have lost that access.

| Field      | Details               |
|------------|-----------------------|
| Event date | 10/03/23              |
| User role  | Legal / Administrator |
| Source IP  | 152.207.255.255       |

### Issues identified

| Finding                                                                                  |
|------------------------------------------------------------------------------------------|
| Robert Taylor Jr. holds admin privileges                                                 |
| His contractor agreement ended in 2019, but his account accessed payroll systems in 2023 |
| No account expiration was enforced after the contract ended                              |

**ROOT CAUSE** A four-year-old contractor account retaining admin access to payroll is a textbook least-privilege failure — the account should have been deprovisioned the moment the engagement ended, not left to be discovered years later.

### Recommendations

| Recommendation                                                   | Rationale                                                            |
|------------------------------------------------------------------|----------------------------------------------------------------------|
| Auto-expire accounts after 30 days of inactivity or contract end | Would have prevented the 2023 access entirely                        |
| Limit contractor access to only what the engagement requires     | Reduces blast radius if a contractor account is misused              |
| Enable Multi-Factor Authentication (MFA)                         | Adds a barrier even if a stale credential is still technically valid |

## 2 Incident 2 — Data Leak via Overpermissioned Sharing

A sales manager shared a folder of internal-only documents — including an unannounced product and customer analytics — with their team during a meeting, and never revoked access afterward. A sales rep later meant to share a public promotional link with a business partner but pasted the internal folder link by mistake. The partner then posted that link publicly, assuming it was the promotional material.

**ANALYSIS** The technical failure and the human error compounded each other: if access to the internal folder had been correctly scoped to only the people who needed it, the sales rep's mistaken share would have exposed nothing sensitive.

### NIST CSF mapping

| Function | Category              | Subcategory                              | Reference            |
|----------|-----------------------|------------------------------------------|----------------------|
| Protect  | PR.DS — Data Security | PR.DS-5 — Protections against data leaks | NIST SP 800-53: AC-6 |

### AC-6 — Least Privilege (NIST SP 800-53)

| Control      | Only the minimal access and authorization required to complete a task should be provided to users                                          |
|--------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| Discussion   | Processes, accounts, and roles should be enforced so no user operates at a privilege level higher than necessary for business objectives   |
| Enhancements | Restrict access by user role · auto-revoke access after a time period · log provisioned-account activity · regularly audit user privileges |

### Recommendations

| Restrict access to sensitive resources based on user role |
|-----------------------------------------------------------|
| Regularly audit user privileges                           |

### 3 Quick Reference



Access control — quick reference

NIST SP 800-53 AC-6 -> Least Privilege  
PR.DS-5 -> Protections against data leaks

Least-privilege checklist:

- Auto-expire accounts after inactivity / contract end
- Scope contractor access to only what the engagement needs
- Enable MFA on all privileged accounts
- Regularly audit who has access to what